

Sovereignty Is a Risk Decision

Sovereignty at AI Speed: Foundation

Roger Halbheer, Field CISO

The argument, for people who decide. The mechanics are in the companion paper, [Digital Sovereignty In Practice](#). It maps this argument to the EU Cloud Sovereignty Framework and to the controls that implement it.

The argument in four lines

1. **Sovereignty is risk management, and the unit is the workload, not the company.** There is no organization-wide sovereignty posture worth having. Every workload carries different exposure and deserves a different answer. The single most expensive mistake is to decide once and apply it everywhere.
2. **It has a price, paid in money, people and speed.** Speed here means **security speed**: how fast you detect, decide and act when an attacker is already inside your systems. The price is close to nothing at the start of the curve and enormous at the end. Most organizations buy at the wrong end.
3. **Being compromised is not sovereignty.** An estate an attacker has already broken into gives you no control over your data, whatever the contract says. **Two risks sit in this debate. One is measured in minutes and named victims. The other is very unlikely and cannot be quantified at all.** That difference should drive the order in which you act.
4. **Sovereignty you have never exercised is not sovereignty.** It is a line item.

If you stop reading here, you have the paper. The two chapters in the middle take one risk each, in the order I think you should work on them.

One disclosure before the argument, because it is the cheapest attack available against it. I am a Field CISO at Microsoft. An argument that customers should spend less on jurisdictional independence and more on security operations happens to suit my employer. So read the evidence, not the author. That is why every claim below carries its source, and why the case I put closest to the center of the argument is the most serious documented intrusion against my own company.

Sovereignty is risk management

Read sovereignty as independence and you will buy it everywhere, at full price, for exposure most of your estate never carried. The textbook definitions push you that way. They call it the ability to act independently and self-determinedly in the digital world. So you reach for independence as the goal, and you try to make everything sovereign.

That single misread is what turns sovereignty into theater.

You cannot buy independence at any sensible price

Before pricing independence, check whether it is even for sale. For a European organization it is not. That honest sentence is worth saying out loud, early.

Start with the number Europe's own institutions publish. The European Commission states that the Union "currently relies on non-EU countries for over 80% of key digital products, services, infrastructure, and intellectual property".¹ **That is Europe describing Europe, not a vendor describing its customers.**

Take the stack apart layer by layer and the dependency runs from the silicon to the search box. A study for the European Parliament's industry committee mapped it in December 2025. Read the table as market concentration, which is what it measures.

Layer	What the evidence says
Leading-edge chips	Total autonomy in microchip production is "impossible". The EU is forecast to reach 11.7 percent of global production by 2030, against a 20 percent target the auditors called overly ambitious. ²
Cloud infrastructure	The three US hyperscalers hold about 70 percent of the EU market. The combined share of EU providers had fallen to roughly 13 percent by 2022. ³
Enterprise software	Around 80 percent of EU corporate spending on software and cloud flows to US vendors. ³
Operating systems	Android and iOS account for virtually all mobile use. Windows holds about 73 percent of the desktop. ³
Security tooling	US and Israeli vendors dominate firewalls, identity management and SIEM. European firms concentrate in services and in operational technology niches. ³
Public sector IT	Administrations rely heavily on US productivity suites and clouds, with only isolated open-source migrations. ³
DNS, the internet's naming system	Every name your business uses resolves from one master list, the root zone. Thirteen authorities answer for it: ten US organizations, one Japanese, two European. ⁴

The layers are not equivalent, and treating them as one problem produces the two worst outcomes. Read the table as uniformly hopeless and you get paralysis: we depend on everything, so why try. Read one row and declare victory and you get the press release: we bought a sovereign cloud, so we are covered. **The rows carry different prices and different timelines,** and only a per-layer reading tells you which ones you can actually move.

On DNS specifically, because it is the row usually told badly. The US government gave up its authorization role over the root zone in 2016, and decisions are now made through a multistakeholder process Europeans take part in. **Nobody is doing anything wrong.** Europe simply carries a concentration it did not choose and cannot purchase its way out of.

And the layer everyone assumes is neutral is not. Open source arrives as a product: a US company's distribution, its support contract, its container registry, its package repository. GitHub's own trade controls page states that its understanding of US export law "does not give us the option to allow downloads or deletion of private repository content, until otherwise authorized by the U.S. government."⁵ **The license is free. The supply chain is not.**

Europe is not standing still. The Commission adopted a Tech Sovereignty package on 3 June 2026 containing a second Chips Act, a Cloud and AI Development Act and an EU Open Source Strategy. ¹ **None of it changes what you can buy this quarter.** Treat it as a trigger to watch, not a control you can show an auditor today.

The dependency chain does not stop at your own platform

You can raise the sovereignty level of your own environment and still have your data sitting somewhere that has none. Payroll. CRM. Ticketing. E-signature. Backup. Security monitoring. **Each holds a copy of some part of your data, each sits in its own jurisdiction, and each has subprocessors you have never enumerated.**

This is where sovereignty programs quietly fail. The core platform gets the attention, the contract and the budget. The twenty other systems holding the same data get a procurement checkbox. **A legal order and an attacker both take the cheapest route in,** and that is rarely the system you hardened.

So list every third party that holds or processes data for the workload you are protecting. Name the jurisdiction, name its subprocessors, and say what happens if that supplier is compelled, breached or withdrawn. **If the list is longer than you expected, that is the finding.**

A sovereignty claim covering one platform while twenty suppliers hold the same data is not a sovereignty claim. It is a statement about one supplier.

This is not an argument for giving up. It is an argument for precision. If full independence is off the table, the question was never "how do we become independent". It was always **"which specific dependencies matter for this workload, and what do we do about those"**.

Asked that way, the question has answers: a second supplier where one exists, tested failover, an exit plan you have actually run, a contract that says what happens on a bad day. **Asked the other way, it has none.**

Sovereignty you can actually engineer is not a state of independence you reach. It is a risk you manage, one workload at a time. The questions are plain: who can do what to this data, under which laws, and what happens in an exception.

Put that conversation in the risk register, next to the other enterprise risks. Not in a procurement negotiation. Not during a news story. Once you assess sovereignty like every other risk, the emotion leaves the discussion and a real conversation becomes possible.

The price, in three currencies

Every step you take to keep more control of your data, your keys and your operations costs you some mix of three things. Organizations price one of them and ignore the other two.

- **Money.** The currency everyone counts, and the one that misleads. It looks like a procurement decision. It is not.
- **Speed,** and I mean **security speed:** how long it takes you to see an intrusion, decide, and act. Attackers keep compressing the time from access to impact, so that number matters more than how many controls you own. **This is the argument of Security at AI Speed, and I will not repeat it here.** ⁶
- **People.** The currency nobody counts, and the one you cannot buy your way out of.

Business innovation speed is a real cost too, and I am not dismissing it. But it is a separate argument, for a separate audience. Mixing the two is how sovereignty discussions lose their force.

Look harder at the third one, because it is where the plans break. A self-operated sovereign environment needs:

- **Skills**, in platform, identity and security, all three at once.
- **Patching, backup and recovery**, done properly rather than in principle.
- **Twenty-four hour coverage**, because attackers do not work office hours.
- **Runbooks**, the step-by-step procedures, written well enough to hold when people are tired and frightened.

That is a permanent staffing commitment, in a market that does not have the staff. In the ISC2 2025 Cybersecurity Workforce Study, **33 percent said their organization does not have the budget to adequately staff its teams, and 29 percent could not afford to hire staff with the skills they need.** ⁷ The data is global and self-reported, so treat it as a signal rather than a measurement. **You are proposing to add a second estate to that.**

The cost is not a straight line, and that is the opportunity

What follows is my model, not a measured finding.

If every increment of control cost the same slice of the three currencies, sovereignty would be a grim trade. It is not. The curve is steep only at the end. The first moves are close to free.

Take the control people argue about most. Whether a provider can produce your plaintext, the readable version of your data, is a question of where the keys live. **At the cheap end of that range it is a configuration change, not a re-platforming.**

It is not free, and I would rather say so than sell it. Every step toward a key the provider cannot use costs you something real. The next chapter prices it. **Price it for the specific workload, instead of assuming it is small.**

The expensive end of the curve is a different world. Environments that run disconnected from the public cloud, fully customer-operated, with their own headcount and a permanent loss of capability. That end is justified for very few workloads. Most of the benefit is available cheaply. Most of the pain sits at an extreme that almost nobody needs.

The real choice is never the simple picture people draw. It is not trust the hyperscaler, a large global cloud provider, or do it all yourself. Those are the two ends of a curve, and the decisions that matter live in the middle. The skill is to take the cheap control broadly, and to refuse the expensive control everywhere except where a workload genuinely cannot survive without it.

The middle is more crowded than this paper has so far admitted. A European board's real shortlist in 2026 includes European providers and European-operated arrangements, as well as the two poles. A procurement head will raise that in the first two minutes.

Everything in this paper applies to them unchanged: price the exposure, read the contract, trace the dependency chain, and ask what has been exercised.

A European brand might answer the jurisdiction question, and that is worth checking rather than assuming. Plenty of European-branded providers are European subsidiaries of global groups, or joint ventures licensing a non-European platform. **Ask who owns the entity, which parent can direct it, and whose law reaches that parent.** Do not go by the logo. **That question includes the arrangements built on my own**

employer's technology, and I am not exempting them from it. The stack underneath is largely the same either way.

Being compromised is not sovereignty

Two risks sit in this debate, and this is the one I want you to look at first. It empties your data out of your environment while the other is still being discussed in a procurement meeting.

An environment an ordinary attacker has already broken into is not a sovereign environment.

Whatever assurance you bought about who may lawfully access your data is void the moment somebody is accessing it unlawfully. **Security is a precondition of sovereignty, not a parallel program. A compromised estate has neither.**

And this one you can measure.

The evidence is abundant and timestamped. It is also all vendor telemetry, none of it independently audited. Read it as directional, not as a precise clock.

- **The average eCrime breakout time, the time from initial access to lateral movement, was twenty-nine minutes in 2025, and the fastest breakout CrowdStrike has ever observed was twenty-seven seconds.**⁸
- **The median time between an initial access event and the handoff to a second threat group fell from more than eight hours in 2022 to twenty-two seconds in 2025.**⁹
- **ENISA analyzed 4,875 incidents in the year to 30 June 2025. Of those it could attribute to a sector, public administration was the most targeted in the European Union at 38.2 percent, and NIS2 essential entities accounted for 53.7 percent of all recorded incidents.**¹⁰

Three cases, none of which turns on jurisdiction

In August 2025, attackers used long-lived OAuth tokens belonging to the Salesloft Drift AI chat agent to reach data in a large number of downstream Salesforce tenants. An OAuth token lets one application act for another. Google's threat intelligence group reported on 26 August 2025. It assessed the actor's primary intent was to harvest credentials, and later advised customers to treat every authentication token connected to the platform as compromised.¹¹ The root cause Salesloft ultimately reported was undetected access to its own source code repository months earlier. What made it spread was a standing, long-lived credential with access into a large number of customer tenants. **That is a machine identity and third-party integration failure.** A machine identity is a credential used by software, not a person. AI agents multiply exactly that class of credential.

From late November 2023, and undetected until 12 January 2024, an attacker reached corporate mailboxes at Microsoft. The method was password-spraying, guessing common passwords across many accounts, against a legacy, non-production test tenant account that had no multifactor authentication. The attacker then pivoted through a legacy test OAuth application that had elevated access to the corporate environment.¹² An unretired identity and an over-permissioned application defeated the security program of one of the largest security vendors in the world. No jurisdiction featured anywhere in that chain.

It is my own company, and I should name the other case before somebody else does. In 2023 Storm-0558 forged authentication tokens with a stolen signing key and reached the mailboxes of government customers. On the Board's findings that was 22 organizations and more than 500 individuals. The US Cyber Safety Review Board attributed it to a cascade of avoidable errors and a corporate culture that had deprioritized security investment.¹³ **All three are identity failures. None of them is a jurisdiction failure,** and no sovereignty control on anybody's slide would have prevented any of them.

Now the part that matters, and it is not the part people quote. Both Microsoft cases were disclosed publicly. The Midnight Blizzard disclosure carried detection guidance for every defender, not only for the customers affected. Storm-0558 went to an external review board that was free to criticize the company as harshly as it wished. The company cooperated, and the findings became a public document.

The same board was blunt that the response was not clean. It found the company's security culture inadequate, and criticized it for failing to correct inaccurate public statements about how the intrusion occurred until March 2024. **Both halves belong in the record, and I am not going to quote only the flattering one.**

So the question a board should ask is not whether a provider has been breached. Every serious one has. A provider with no incidents to describe is more likely to be early in its history than exceptional. **The questions are: how quickly was it found, who was told, what did other defenders get out of it, and what changed afterwards.** Those are answerable from the public record, not from a promise.

And do not build your expectations on the review board, because it no longer sits. Its members were removed in January 2025. So a buyer cannot assume that mechanism will recur. **The durable version is regulatory, and it is already yours.** NIS2 and DORA put incident reporting obligations and timelines on providers and on you. They are the thing to write into a contract and ask about in a review. **A commitment you can point at in law outlasts a board that can be dissolved.**

What differs is not whether you get hit

This is the speed argument arriving from the other direction, and it runs through the whole estate, not only the headline incidents. When an attack pattern is seen against one tenant on a hyperscale platform, the detection built for it can be shipped to every other tenant. **Be precise about the limits.** Timing varies, and the sharing depends on telemetry settings you control. So it is a capability, not an automatic guarantee.

In a self-operated estate, every lesson is one you learn yourself: on your own incident, with your own people, at three in the morning. No external board reviews your breach. No published guidance comes out of it. **The detection engineering, the threat intelligence, the automated response and the newest AI tooling all sit on the platforms.** A workload moved away from them is defended with whatever you can staff and build alone.

That is the trade, and it should be made deliberately. For a genuinely must-run workload it can still be the right call. For most workloads it is not.

Three things I will not claim

I will not claim the cloud is safe. Cloud-conscious intrusions rose 37 percent year over year, including a 266 percent increase among state-nexus actors, meaning attackers linked to a government. That is from CrowdStrike's 2026 Global Threat Report.⁸ The claim is that compromise is where sovereignty is actually lost, not that any platform prevents it.

I will not claim AI is now the cause of breaches. Mandiant's own 2026 position is that the vast majority of successful intrusions still stem from fundamental human and systemic failures.⁹ AI is changing the tempo and adding an identity surface. It has not replaced the basics.

And I will not claim self-operated estates are measurably less secure, because nobody has measured it.

No published study compares breach outcomes of self-hosted against cloud-operated environments, controlled for size and sector. The argument runs on observable mechanisms instead: multifactor coverage, patch latency, out-of-hours response capacity, log retention. Each is separately evidenced. Each is where the difference actually shows up.

That is the risk you can count. It gives you a number today, it moves in minutes, and it voids your sovereignty claim entirely when it fires.

Now the other one, which is the risk most sovereignty programs are actually built around.

The risk you are afraid of, and what it actually is

The fear behind most sovereignty programs is simple: a foreign government compels your provider to hand over your data. That fear is legitimate. A second fear, that your service is switched off for political reasons, sits on much thinner evidence. I deal with it at the end of this chapter.

Here is what that risk actually consists of. Whose law reaches you. What key control does and does not do. Why your provider is less a threat and more an ally than the debate assumes. And what the risk can honestly be measured at.

The legal question is not a US question

I am not a lawyer, and none of what follows is legal advice. It is my understanding of the landscape after a lot of reading. It is here to make one point only: **compelled access to data held by a provider is not an American peculiarity.** If your sovereignty argument rests on escaping one jurisdiction, check what the others require first.

Before the examples, one thing needs saying, because the rest of this section reads like a list of threats and it is not. These laws exist because societies asked for them.

Police need to reach data to do their work. Terrorism, child sexual abuse material, human trafficking, fraud that empties a pensioner's account: every one of those investigations ends up needing evidence that sits on somebody's server. **A country whose police could never compel a provider would be a very comfortable place to run a criminal enterprise.** That is a description of the trade-off, not a position on where any particular law should draw the line.

So the question is never whether these powers should exist. It is whether they are properly bounded: a legal basis, an independent authorization, a limit on scope, a route to challenge, and some way for the rest of us to see that the system works. **Those are the things worth comparing between jurisdictions, and they are what the examples below actually show.**

Keep the two questions apart, because most sovereignty discussions mix them. "Can a government compel my provider" is answered yes, almost everywhere. **"Under what conditions, with what oversight, and can I see it happening" is the question that separates one jurisdiction from another,** and it is the one worth your time.

What follows is three national examples, plus the European instrument most people miss. It is nowhere near a complete picture. I picked instruments that make the point economically. They are not the strongest or the most recent, and not a representative sample. **Almost every country with a developed legal system has some version of this.** Most have several. Any serious assessment has to start from the jurisdictions you actually touch, not from a list in someone's paper. Treat these as illustrations that the question is universal. Then go and ask your counsel about yours.

The United Kingdom can compel a provider to build a capability, not just to hand over what it already holds. It does this with a technical capability notice, an order to build or change a capability, under the Investigatory Powers Act 2016. Such a notice may be given to persons outside the UK, and require things done outside the UK. It may extend to removing electronic protection applied by or on behalf of the operator.¹⁴ It is gated: necessity and proportionality, Judicial Commissioner approval, and a separate warrant for the access itself. **Those constraints are real, and they are all internal to the regime.**

That power has been reported to have been used. It was reported in February 2025 that the Home Office had served Apple with such a notice over encrypted iCloud data, and in October 2025 that the first notice had been withdrawn and replaced with a narrower one.¹⁵ **None of it is confirmed, because the regime prohibits confirmation,** and the Tribunal expressly declined to say whether the reporting was accurate.

What is on the record is narrower. Apple brought proceedings. On 7 April 2025 the Tribunal refused the Government's application to keep even the bare details of the case secret. Apple withdrew Advanced Data Protection for new UK users on 21 February 2025. Related challenges were understood to be continuing when this paper went to press. **Verify the current position before relying on it.**

France can require certain providers to hand over decryption keys within seventy-two hours. The duty falls on providers of cryptology services that perform a confidentiality function. It covers the keys that decrypt data encrypted by means of the services they themselves supplied. The request comes from agents authorized under the procedure in article L821-4.¹⁶ **It binds cryptology providers, not cloud providers at large.**

Germany points the other way, and it deserves the concession. Its Constitutional Court held in 2020 that German fundamental rights bind state authority beyond German territory and protect foreigners abroad. There is no direct United States counterpart to that.¹⁷ Germany still compels providers under its own criminal procedure and intelligence law.

So the honest claim is narrower than the one usually made, and it is not a claim about which jurisdiction is worst. On the evidence of these examples, and others like them, the powers are broadly comparable across jurisdictions. The constraints are not. **Claim more than that, in either direction, and the first lawyer in the room will take the claim apart.**

Whether any given one of these instruments is drawn correctly is contested, and in the United Kingdom it is being contested in court right now.

The European Union built one too, and it applies now

This is the one worth a minute, because it is ours and because most people do not know it exists. The e-Evidence Regulation (EU) 2023/1543 has applied since 18 August 2026.¹⁸

It does structurally what the CLOUD Act does. An authority in one member state sends a production order **directly to the provider** in another, skipping the mutual legal assistance route that used to take months. Ten days to produce, **eight hours in an emergency.** Member states must back it with penalties reaching up to two percent of worldwide annual turnover. The accompanying directive requires any provider offering services in the Union to name an addressee for these orders, wherever it is headquartered.

Two honest qualifications. It operates inside a mutual-recognition area, with common fundamental-rights standards and broader grounds for refusal. So it is a structural analogue, not an equivalent. And it is running ahead of its own infrastructure. Transposition of the accompanying directive was due on 18 February 2026, and in March 2026 the Commission opened infringement proceedings against twenty-two member states for missing it, while the exchange system itself was still under active development.¹⁹ **Expect practice to be messier than the text for a while.**

The point for a board is not that e-Evidence is bad. It is that "move it to Europe so no government can compel the provider" is not a description of European law. Europe compels providers too, across borders, on an eight-hour clock.

One correction, because it appears in almost every sovereignty deck

On my reading, the EU Blocking Statute does not help you here. Regulation 2271/96 nullifies the effect of foreign judgments based on the laws in its annex. The Commission's own description of that annex is that it "currently consists of U.S. measures concerning Cuba and Iran."²⁰ **Neither the CLOUD Act nor FISA Section 702 appears there.** The Commission does not address either instrument on that page, so that conclusion is mine, not the Commission's. Citing it as a safeguard against compelled cloud disclosure is wrong as the annex currently stands. It is the kind of mistake that discredits the rest of your case.

What key control is, and what it does not buy you

The legal points here carry the same caveat as the section above: this is my reading of the instruments, not legal advice.

Key control means three different things. One: a key you hold on your own premises. Two: a key you generate and bring to the cloud. Three: a key you own that the provider stores and operates in its hardware security module, a tamper-resistant device that guards keys. The companion paper works through the trade in each. **The one that hurts customers most often is the second.** The key is imported, the local copy is treated as a formality, the backup is lost, and the data goes with it. Note that the vendors call all three customer-managed. None of them is a provider-managed key.

There is a fourth arrangement, and it is the default almost everywhere: a key the provider generates, holds and uses on your behalf. Microsoft's own documentation is blunt about it. It says that server-side encryption using platform-managed keys "means the service has full access to store and manage the keys". AWS describes its own default key type, which it calls an AWS owned key, in the same terms: "the service operators have the ability to manage its lifecycle and usage permissions" and "you cannot audit activities on these keys."²¹ **No comparison between providers is intended. Both are quoted to show the default is an industry norm, not one vendor's choice.**

Read that as a feature description, not a confession. The service has access to the keys **because you want it to have access to the content.** Anti-malware scanning, data loss prevention, search and indexing, eDiscovery, classification, summarization, and every assistant you are now rolling out: all need the service to read the data. **You cannot scan what you cannot decrypt.**

The default is the setting that buys the functionality, and for most data it is the right setting. It is still not key control, and it should not be sold to a board as if it were. In the default model the honest answers are plain: the provider holds the key, the provider authorizes its use, and you get no evidence you can independently verify.

Which makes the real trade clear, and it is not a trade about jurisdiction at all. Every step toward a key the provider cannot use is a step away from the features that depend on reading your content. **That cost is immediate and certain. Weigh it against an exposure that is very unlikely and unquantifiable.**

State it as a rule, and get the variable right, because most decks get it wrong. What costs you functionality is not how far the key sits from the service. It is whether the service ever sees plaintext. A customer-managed key, even one held in your own hardware, still lets the service decrypt, and so still works with search, scanning and data loss prevention. **Double Key Encryption and client-side encryption are different.** There the service never sees the content, so the content-dependent functions stop.

That is the line to draw in a workshop. For a narrow class of data, a design where the provider genuinely cannot read the content is exactly the right bargain. **For the rest of the estate it costs you content-dependent controls, among them scanning and data loss prevention, that you were otherwise relying on.**

Now the limit, and it is larger than the reassuring version of this section admits. Holding the key yourself moves where the pressure lands. It does not remove it.

A British notice can reach electronic protection applied by or on behalf of the operator. On its face that includes encryption performed by software the operator supplies to you, whether or not the operator ever holds the key. **That, on the reporting, is what the Apple matter was about.** Apple's design for that feature is one in which Apple does not hold the keys, which is why the reporting described the architecture itself as the target. **None of that is confirmed, and the regime prohibits confirmation.**

Separate powers in several jurisdictions, including France and the United Kingdom, target the key holder directly rather than the provider. ²² Customer-held keys are still worth doing for a narrow class of data. They still have to be genuinely yours, not a provider-managed key relabeled on a slide. **They are not an exit from the legal question.**

Why I read the risk as very unlikely: your provider is on your side

The debate treats the provider as the channel through which a government reaches you. It is at least as accurate to treat it as the party standing between the two.

The major providers publish commitments here. They will redirect government requests for enterprise data to the customer, notify the customer where law permits, and challenge orders in court where there is a lawful basis. ²³ Microsoft has litigated this, not just theorized it. In 2016 it sued the Department of Justice over indefinite secrecy orders. That ended in October 2017, when the Department changed its policy on their use. ²⁴

In April 2025 Microsoft went further for European customers. As of April 2026 it states the commitment is legally binding in those contracts, including, in its own words, a commitment to "promptly and vigorously contest in court any order by any government to suspend or cease cloud operations in Europe." ²⁵ **Read the scope in the contract, not here.** The binding contractual form is for contracts with European national governments and the European Commission, not for every customer. **I am describing a published commitment, not giving one.**

None of this is distinctive to one provider, and I am not going to pretend otherwise. ²³ I am deliberately not comparing them, and neither should a slide. **The only comparison worth anything is the contract text, read side by side.**

The useful conclusion is not about which vendor. It is that if a request arrives that does not meet the legal standard, you are not alone in the room. Your provider has its own commercial survival to protect, its own general counsel, and a public record to defend. Those interests point the same way as yours.

So the practical question in procurement is not "could they be compelled". It is: what does this provider commit to contest, is that commitment contractual or a blog post, what will they tell you and when, and what is their actual litigation record. **Ask every provider on the shortlist for the clause in writing, and compare the text, not the press release.**

What this risk can be measured at

There is very little here, and what exists is self-reported. As of September 2026 I am aware of no publicly documented case of a CLOUD Act order against a named European enterprise or government cloud customer. And I have looked. **If you know of one, it belongs in this argument, and I would like to see it.** The nearest data point is an aggregate line in one vendor's own transparency report. Both halves belong here. Microsoft's Government Requests report for July to December 2025 records content data provided to United States law enforcement for three non-US enterprise customers with data stored outside the US, one of them in the EU or EFTA.

Separately, and more broadly, of the enterprise content disclosures in the period, Microsoft states that "none of these disclosures involved Azure content data belonging to a commercial, public sector, or educational customer."²⁶ **It is self-declared and not externally audited.**

That absence has two readings, and intellectual honesty requires carrying both. Either the risk really is very rare in practice. Or the secrecy regimes are working exactly as designed. United States non-disclosure orders, the British ban on confirming a technical capability notice, and the French defense secret all make confirmation unlawful. **Assert only the first and you overstate. Assert only the second and you cannot be proved wrong.**

I said at the front that I read this as very unlikely. Here is why, and here is what the judgment does not entitle me to. The volume of European cloud data never touched this way is the whole market over two decades. **You still cannot put a number on this risk.** You cannot assign it a likelihood band in your register. You cannot track whether it is rising. Nobody will give you the data.

One quotation belongs here, not in the question period. Before the French Senate on 10 June 2025, Microsoft France's Anton Carniaux was asked whether he could guarantee French data would never be transmitted on a US injunction. He answered: "Non, je ne peux pas le garantir, mais, encore une fois, cela ne s'est encore jamais produit". In English: no, I cannot guarantee it, but then again, it has never yet happened.²⁷

And the switch-off fear, which I promised to come back to

The clearest documented case of hyperscalers withdrawing cloud services from an entire country's registered companies was the round of suspensions in March 2024, Microsoft among them. Those were compliance with the European Union's twelfth sanctions package, not a United States action.²⁸ **A reader who fears an American switch-off should know that this one was ordered from Brussels.**

If you want a structured estimate rather than an argument, one exists. David Rosenthal's Transfer Impact Assessment toolbox puts a probability on foreign lawful access for a defined transfer and period. And it is free.²⁹ **It is a documented method, not a measurement.** Working through it for one real workload beats another round of the debate.

So: a real risk, judged very unlikely, that you cannot quantify. Set that against the risk in the previous chapter, which is counted in hours and in named victims. **Both are real. Only one of them tells you where to start.**

Untested sovereignty is not sovereignty

This is the claim that makes the other three auditable.

An exit plan that has never been run is not an exit plan. A disconnection capability never exercised. A key recovery never rehearsed. A twenty-four hour approval rota that does not exist at three in the morning. Each of these costs full price every day, and none will execute under pressure. You are paying for independence and holding a document.

Exchange: what self-hosted email actually costs to keep safe

Think about what on-premises Exchange actually is. Your building. Your hardware. Your administrators. No provider touching your mail. **It is what a sovereignty program tells you to build,** and tens of thousands of European organizations did exactly that.

Now look at the state of it. Microsoft support for Exchange Server 2016 and 2019 ended on 14 October 2025. No more security updates. Two weeks later the German federal security authority counted the servers in its own country: **92 percent of roughly 33,000 on-premises Exchange servers with Outlook Web Access reachable from the internet were still running 2019 or older.** ³⁰

Then a number that needs no percentage. After the end of support, security updates for those versions are available only through Microsoft's Extended Security Update program: optional, paid, time-limited, sold per server as a separate contract, and available only to organizations that hold a Microsoft Enterprise Agreement. In late August 2026 the German CERT reported how many servers in Germany it could see with those patches installed. **Nine.** ³¹

Nine, against a national population the BSI put at roughly thirty thousand internet-facing servers ten months earlier. The two figures come from different dates and different methods, so read the gap as an order of magnitude rather than as a ratio.

And here is the part I had wrong until I checked. I used to describe on-premises Exchange, in this argument and in earlier drafts of it, as sovereign because no provider has any access. That is no longer true in the way that matters. **A supported Exchange on your own hardware now means Exchange Server Subscription Edition.** The paid update program that bridged the gap ends on 31 October 2026, and Microsoft has said it will not be extended again. You own the building and the hardware. **The security updates arrive under a separate commercial agreement with a US vendor, for as long as that agreement is on offer.** These organizations own the sovereign part. The part that keeps it safe is now a separate, time-limited purchase, and not all of them are even eligible to make it.

Two concessions, because this argument attracts both.

First, organizations can patch, and the curve can be steep. During the 2021 ProxyLogon emergency Microsoft reported on 22 March that 92 percent of internet-facing Exchange servers worldwide were patched or mitigated, a 43 percent improvement in the preceding week alone, three weeks after the out-of-band fix. ³² **The problem is not that patching is impossible. It is that the tail never closes,** and the tail is where the breaches happen.

Second, and most important, this proves less than it looks. It says nothing about sovereignty in general. It says something about **self-operation** at population scale. A European managed provider patches its customers' mail servers, and a well-run organization patches its own. **Substitute any other self-hosted mail platform and the argument should still hold.** If it only works with Exchange, it is a sales pitch. If it works with the alternatives too, it is an argument. **And say the uncomfortable part plainly: Microsoft wrote this software, Microsoft set the end-of-support date, and Microsoft prices the bridge.** None of that changes what the German numbers show about self-operation at population scale, and all of it belongs on the page.

So take the narrow version, because it is the one that survives. If your sovereignty answer is "we will run it ourselves", this is the published record of what running it ourselves looks like across a whole country.

Sovereignty is not the server you own. It is the work you keep doing after you own it.

The three questions that replace the assurance statement

The test of every sovereignty control is not whether it is contracted. It is this:

- **What is the exercise that proves it works, and when was it last run?**
- **Who failed the exercise, and what changed as a result?**
- **What is the evidence a regulator or an auditor would accept, as opposed to an assurance statement?**

A sovereignty assurance level asserted in a procurement document is paperwork. The same level exercised on a schedule is sovereignty. That distinction is the whole content of the companion paper.

What this looks like on Monday

These are engineering and risk-sequencing recommendations, not legal advice. Whether a given regulation requires residency for a given workload is a question for your counsel. The answers differ by sector and member state.

Pick your three most contested workloads and write one page each. Which specific exposure you are reducing, what it costs in money, people and speed, and how you would prove it works. **If you cannot fill the third box, you have not bought anything.**

Take the cheap end of the curve broadly. Use customer-managed keys wherever the workload can afford the functionality they cost. Add access transparency, and residency where your counsel confirms regulation requires it for that workload. **Be explicit about the capability each step removes.**

Ask every provider on your shortlist for the clause in writing. What they commit to contest, in which contract, what they will tell you and when. **Compare the text, not the press release.**

Reserve the expensive end for the must-run few, where a forced stop would be existential and slow recovery is unacceptable. Be explicit that you are accepting a permanent capability and staffing cost to get it.

Fund the measurable risk first. Identity hygiene, retirement of legacy authentication paths, governance of non-human and agent identities, and the ability to detect and respond inside the window the threat reports describe. None of that is a sovereignty program, and all of it is a precondition for one.

Say out loud what would change the sequencing, or you are describing a permanent deferral.

Sequencing is not deferral only if the trigger is written down in advance. Mine would be:

- **A change in the legal instruments** that removes the discretion a provider currently has to contest an

order.

- **A documented case** of compelled disclosure or service withdrawal affecting an organization like yours.
- **A regulatory obligation** that makes a specific assurance level mandatory rather than desirable.
- **A business change** that moves a workload into the must-run class.

Write your own triggers, put a date on the review, and give them to the board. A risk you have agreed to revisit on a trigger is managed. A risk you keep meaning to get to is not.

Exercise everything you claim, on a schedule, and write down what broke. If you run only one exercise this year, restore a critical workload onto infrastructure you would actually have after an incident, and see whether it comes back.

The test of a sovereignty strategy is not whether it sounds sovereign. It is whether, for every critical workload, you can say which risk you accepted, which you reduced, what it cost you in money, people and speed, and when you last proved it works. If you cannot, you do not have a strategy. You have a slogan.

Notes

1. European Commission, Strengthening Europe's Tech Sovereignty. <https://digital-strategy.ec.europa.eu/en/policies/eu-tech-sovereignty> - source of the quoted "over 80%" figure and of the Tech Sovereignty package adopted on 3 June 2026, which contains the Chips Act 2.0 and Cloud and AI Development Act proposals, the EU Open Source Strategy and a strategic roadmap for digitalisation and AI in energy. The Commission does not publish the derivation of the 80 percent figure on that page. [↗](#) [↗](#)
2. European Court of Auditors, Special Report 12/2025 on the EU's microchip strategy, 28 April 2025. <https://www.eca.europa.eu/en/publications?ref=SR-2025-12> [↗](#)
3. European Parliament, European Software and Cyber Dependencies, study for the Committee on Industry, Research and Energy (ITRE), PE 778.576, December 2025, prepared by Visionary Analytics. https://www.europarl.europa.eu/RegData/etudes/STUD/2025/778576/ECTI_STU%282025%29778576_EN.pdf - two-page summary at PE 780.413, https://www.europarl.europa.eu/RegData/etudes/ATAG/2025/780413/ECTI_ATA%282025%29780413_EN.pdf. **The study measures market concentration, not legal exposure**, and its own underlying figures come from third parties: the EU provider share from Synergy Research Group (2022), the 80 percent enterprise spending figure from an Asteres study commissioned by Cigref (2025), and the operating system and search shares from Statcounter (2025). The opinions in the study are the authors' and are not an official position of the European Parliament. [↗](#) [↗](#) [↗](#) [↗](#) [↗](#)
4. Root zone maintenance: ICANN, Root Zone Maintainer Agreement, <https://www.icann.org/en/stewardship-implementation/root-zone-maintainer-agreement-rzma> - under which Verisign compiles the root zone file at the direction of the IANA functions, signs it, and distributes it to the root server operators. Root server operators: IANA, Root Name Servers, <https://www.iana.org/domains/root/servers> - thirteen named authorities. Ten are operated by United States organizations (Verisign operates A and J; ICANN L; University of Southern California B; University of Maryland D; NASA Ames E; Internet Systems Consortium F; Cogent C; US Department of Defense G; US Army Research Lab H). The WIDE Project in Japan operates M. The two European operators are Netnod (I) and RIPE NCC (K). Each letter is served from many physical sites worldwide via anycast; the operator count is not a count of servers. On the end of the US government's authorization role: NTIA, Verisign Cooperative Agreement, <https://www.ntia.gov/program/verisign-cooperative-agreement> - recording that in October 2016 the Department of Commerce released Verisign from the obligation to obtain NTIA authorization before changing the root zone file. [↗](#)
5. GitHub, GitHub and Trade Controls. <https://docs.github.com/en/site-policy/other-site-policies/github-and-trade-controls> [↗](#)
6. Roger Halbheer, Security at AI Speed, Enterprise Security Perspectives. <https://github.com/rhalbheer/enterprise-security-perspectives/tree/main/Security%20at%20AI%20Speed> - start with Your Security Model Is Too Slow to Matter. [↗](#)
7. ISC2, 2025 Cybersecurity Workforce Study, 4 December 2025. <https://www.isc2.org/insights/2025/12/2025-ISC2-Cybersecurity-Workforce-Study> - global self-reported survey data from a certification body, not a European measurement. [↗](#)
8. CrowdStrike, 2026 Global Threat Report findings, 24 February 2026. <https://www.crowdstrike.com/en-us/blog/crowdstrike-2026-global-threat-report-finding-s/> - breakout time is CrowdStrike's own measure over its own telemetry, vendor-defined and not independently audited. [↗](#) [↗](#)
9. Mandiant / Google Cloud, M-Trends 2026, 23 March 2026. <https://cloud.google.com/blog/topics/threat-intelligence/m-trends-2026/> - vendor-defined and not independently audited. [↗](#) [↗](#)
10. ENISA, Threat Landscape 2025, 1 October 2025. <https://www.enisa.europa.eu/publications/enisa-threat-landscape-2025> [↗](#)
11. Google Threat Intelligence Group, data theft from Salesforce instances via Salesloft Drift, 26 August 2025. <https://cloud.google.com/blog/topics/threat-intelligence/data-theft-salesforce-instances-via-salesloft-drift/> - root cause subsequently reported by Salesloft at <https://trust.salesloft.com/> (accessed 12 September 2026). [↗](#)

12. Microsoft Threat Intelligence, Midnight Blizzard: guidance for responders on nation-state attack, 25 January 2024. <https://www.microsoft.com/en-us/security/blog/2024/01/25/midnight-blizzard-guidance-for-responders-on-nation-state-attack/> [↗](#)
13. US Cyber Safety Review Board, Review of the Summer 2023 Microsoft Exchange Online Intrusion, 2024, published via CISA at <https://www.cisa.gov/resources-tools/resources/CSRB-Review-Summer-2023-MEO-Intrusion> - named here because it is the harder of the two cases against my employer and the argument should not rest on the easier one. **The Board's findings, including its criticism of the company, are quoted from that report. Verify the current location of the document before publication: the Board's members were removed in January 2025.** [↗](#)
14. Investigatory Powers Act 2016 (United Kingdom), section 253. <https://www.legislation.gov.uk/ukpga/2016/25/section/253> [↗](#)
15. Reported by the Washington Post, 7 February 2025, <https://www.washingtonpost.com/technology/2025/02/07/apple-encryption-backdoor-uk/>, and the Financial Times, 1 October 2025. Neither notice has been confirmed: in Apple Inc v Secretary of State for the Home Department [2025] UKIPTrib 1, IPT/25/68/CH, the Tribunal declined at [20] to indicate whether the reporting was accurate, while at [32] rejecting the Government's application to keep the bare details of the case secret. Apple's withdrawal of Advanced Data Protection for new UK users is its own statement, support document 122234, <https://support.apple.com/en-us/122234> - **note that Apple has since revised the page, so cite the withdrawal date to contemporaneous reporting rather than to the page's own published date.** The separate challenge brought by Privacy International and Liberty is IPT/25/83/CH. **This matter has moved twice; verify the position before relying on it.** [↗](#)
16. Code de la securite interieure (France), article L871-1. https://www.legifrance.gouv.fr/codes/section_lc/LEGITEXT000025503132/LEGISCTA000030937362/ [↗](#)
17. Bundesverfassungsgericht, judgment of 19 May 2020, 1 BvR 2835/17. <https://www.bundesverfassungsgericht.de/SharedDocs/Pressemitteilungen/EN/2020/bvg20-037.html> [↗](#)
18. Regulation (EU) 2023/1543 on European Production and Preservation Orders, and Directive (EU) 2023/1544. <https://eur-lex.europa.eu/eli/reg/2023/1543/oj/eng> [↗](#)
19. European Commission, "Commission takes action to ensure complete and timely transposition of EU directives", INF/26/679, 27 March 2026, https://ec.europa.eu/commission/presscorner/api/files/document/print/en/inf_26_679/INF_26_679_EN.pdf - letters of formal notice to twenty-two member states for failing to communicate full transposition of the e-evidence Directive (EU) 2023/1544, against a transposition deadline of 18 February 2026. Note also that a corrigendum to Regulation (EU) 2023/1543 was published in July 2026; check any verbatim quotation from the Regulation against the corrected text. [↗](#)
20. European Commission, Extraterritoriality (Blocking Statute), on Council Regulation (EC) No 2271/96. https://finance.ec.europa.eu/eu-and-world/open-strategic-autonomy/extraterritoriality-blocking-statute_en - annex contents checked 14 September 2026. [↗](#)
21. Microsoft, Azure data encryption at rest and encryption models. <https://learn.microsoft.com/en-us/azure/security/fundamentals/encryption-models> - and AWS Key Management Service concepts. <https://docs.aws.amazon.com/kms/latest/developerguide/concepts.html> [↗](#)
22. Obligations that run at the holder of the decryption key rather than at the service provider: France, article 434-15-2 of the Penal Code, https://www.legifrance.gouv.fr/codes/article_lc/LEGIARTI000032654251/ (version in force since 5 June 2016) ; United Kingdom, Regulation of Investigatory Powers Act 2000, Part III, section 49, <https://www.legislation.gov.uk/ukpga/2000/23/section/49> . Each has its own authorization requirements. [↗](#)
23. Microsoft, Defending your data, 19 November 2020. <https://blogs.microsoft.com/on-the-issues/2020/11/19/defending-your-data-edpb-gdpr/> - each major provider publishes its own commitments in this area; Amazon, Google and Microsoft are all signatories to the Trusted Cloud Principles. No comparison between them is made or implied here. [↗](#)
24. Microsoft, secrecy order lawsuit archive. <https://blogs.microsoft.com/datalaw/initiative/legal-cases/microsofts-secrecy-order-lawsuit/> - and Brad Smith, "DOJ acts to curb the overuse of secrecy orders", 23 October 2017. <https://blogs.microsoft.com/on-the-issues/2017/10/23/doj-acts-curb-overuse-secrecy-order-s-now-congress-turn/> - note that United States v. Microsoft Corp., 584 U.S. (2018) was vacated as moot following the CLOUD Act rather than decided in Microsoft's favor. [↗](#)
25. Microsoft, European Digital Commitments, 30 April 2025. <https://blogs.microsoft.com/on-the-issues/2025/04/30/european-digital-commitments/> - the durable restatement at <https://learn.microsoft.com/en-us/azure/azure-sovereign-clouds/european-digital-commitments> - and Microsoft, One year on: progress on our European digital commitments, 29 April 2026, <https://blogs.microsoft.com/on-the-issues/2026/04/29/one-year-on-progress-on-our-european-digital-commitments/> - which is the source for the legally binding contractual form and its scope. **Microsoft's published wording governs; nothing here modifies it.** [↗](#)
26. Microsoft, Government Requests for Customer Data report, July to December 2025. <https://www.microsoft.com/en-us/corporate-responsibility/reports/government-requests/customer-data> - the most recent reporting period available at the time of writing; check for a later one before publication. [↗](#)
27. French Senate, commission of inquiry into public procurement, hearing of 10 June 2025, record published under the sitting of 9 June 2025. https://www.senat.fr/compte-rendu-commissions/20250609/ce_commande_publique.html [↗](#)
28. Council Regulation (EU) 2023/2878 (the twelfth sanctions package), <https://eur-lex.europa.eu/eli/reg/2023/2878/oj> - with a wind-down date of 20 March 2024, and contemporaneous provider notices to affected customers. Microsoft was among several providers that suspended services in that window. [↗](#)
29. David Rosenthal (VISCHER, Zurich), EU SCC Transfer Impact Assessment Toolbox. Free and author-hosted: <https://www.rosenthal.ch/downloads/Rosenthal-EU-SCC-TIA.xlsx> - index of versions at <https://www.rosenthal.ch/> [↗](#)
30. Bundesamt fuer Sicherheit in der Informationstechnik, warning on the end of support for Exchange Server 2016 and 2019, 28 October 2025. https://www.bsi.bund.de/SharedDocs/Cybersicherheitswarnungen/DE/2025/2025-287772-1032_bits.html and the accompanying press release https://www.bsi.bund.de/DE/Service-Navi/Presse/Pressemitteilungen/Presse2025/251028_Support_Ende_Exchange-Server.html - the 92 percent is of the approximately 33,000 German on-premises Exchange servers known to the BSI with Outlook Web Access openly reachable from the internet. It is not a count of all Exchange servers in Germany. [↗](#)
31. CERT-Bund, quoted by heise online on 31 August 2026 following heise's inquiry to the BSI: "Currently, we are only aware of 9 Exchange servers 2016/2019 in Germany on which patches released as part of ESU are installed." English <https://www.heise.de/en/news/85-percent-of-on-prem-servers-in-Germany-vulnerable-11434806.html> ; German original <https://www.heise.de/news/Exchange-Sicherheitsluecke-85-Prozent-der-On-Prem-Server-in-Deutschland-anfaellig-11434785.html> . The underlying statement is a CERT-Bund post of 28 August 2026 on the BSI's Mastodon account, independently dated by Help Net Security, 2

September 2026, <https://www.helpnetsecurity.com/2026/09/02/microsoft-exchange-cve-2026-62911-critical-authentication-bypass-flaw/> . **CERT-Bund's figure counts servers on which ESU patches were externally observable to CERT-Bund. It is not a count of ESU enrollments.** [↩](#)

32. Microsoft Security Response Center figure of 22 March 2021, as reported by BleepingComputer, <https://www.bleepingcomputer.com/news/security/microsoft-92-percent-of-exchange-servers-safe-from-proxylogon-attacks/> [↩](#)